情報処理安全確保支援士試験　科目A-2　中分類25 情報セキュリティ対策　#10

アクセス制御と利用者認証

だれに何を許すか（アクセス制御）と、本当にその人か（認証）。パスワードの先へ

各ページの下に、根拠にした資料（IPA の支援士試験シラバス案、NIST SP 800-63・800-162、FIDO Alliance、W3C、RFC など）を書いた。過去問は IPA 公開の午前 II 。例の場面は Claude が作った

全体像 シラバス案 中分類25 小分類4「情報アクセスの管理」

1 アクセス制御のモデルと仕組み
DAC・MAC・RBAC・ABAC・最小特権・PAM・セキュア OS・ストレージ／ファイル／DB の暗号化

2 利用者認証の方式
多要素・多段階・リスクベース・フィッシング耐性・OTP・チャレンジレスポンス・エンティティ認証・Identity Proofing・3D セキュア

3 生体認証とパスワードレス
FRR・FAR・EER・ライブネス検知、FIDO・FIDO2・WebAuthn・CTAP・パスキー

過去の午前 II での出方

テーマ	出た回
FIDO UAF の認証の流れ	R1秋
パスキーで生体情報を受け取るのは	R6秋
認証デバイス（虹彩・静電容量・IC カード）	R7秋
SP 800-63-3 の Identity Proofing	R7秋
3D セキュア	R2

> 「生体情報はどこにも送られない」が FIDO の核心。R1 と R6 で形を変えて出た。

出典：IPA「支援士試験 シラバス（案）Ver.0.1」中分類25 小分類4／IPA 午前 II 各回（このPDFの問題演習を参照）

第1章

アクセス制御のモデルと仕組み

だれが決めるのか、何をもとに判断するのか。

アクセス制御の4つのモデル

モデル	だれが決める	判断のもと	特徴
DAC 任意	資源の所有者	所有者が付けた ACL・パーミッション	柔軟／誤って公開しやすい
MAC 強制	システムの方針	主体と資源のラベル（機密区分）	所有者も変えられない
RBAC ロール	管理者	利用者に割り当てた役割	異動はロールの付け替え
ABAC 属性	管理者のポリシー	主体・資源・環境（時刻・場所・端末）の属性	細かい・状況に応じる

Bell-LaPadula（MAC の代表的なモデル）

極秘
「秘」の人は読めない（no read up）

秘
自分の区分

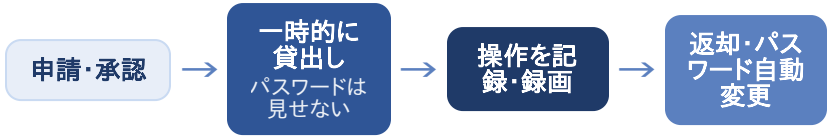
公開
「秘」の人は書けない（no write down）＝下へ漏らさない

略語の MAC は3つある：強制アクセス制御（Mandatory Access Control）、メッセージ認証符号（Message Authentication Code、#15）、MAC アドレス（Media Access Control）。文脈で見分ける。

出典：IPA「支援士試験 シラバス（案）」用語例「MAC, DAC, RBAC, ABAC」／NIST SP 800-162

特権を絞る：最小特権・PAM・セキュア OS

特権アクセス管理（PAM）の流れ



必要なときだけ権限を上げる **Just-In-Time**。常に管理者権限で動かさない。

セキュア OS（SELinux・AppArmor・TOMOYO）

強制アクセス制御＋最小特権。**root でも**方針の外は操作できない。

```
# Web サーバのプロセスに許すのは
httpd_t → /var/www/html   読み取り 許可
httpd_t → /etc/shadow     読み取り 拒否
```

乗っ取られても、**被害を方針の範囲に閉じ込める**。脆弱性そのものはなくならない。

出典：IPA「支援士試験 シラバス（案）」用語例「最小特権，特権アクセス管理（PAM），セキュア OS」。SELinux の例は Claude が単純化

保存データの暗号化：何から守れるか

方式	単位	守れる	守れない
ストレージ暗号化	ディスク全体（BitLocker・FileVault・SED）	紛失・盗難・廃棄	**起動中の端末の乗っ取り**
ファイル暗号化	ファイルごと（IRM・DRM も）	持ち出し・誤送信	**鍵を持つ人の漏えい**
DB 暗号化（TDE）	データファイル全体を DBMS が自動で	データファイル・バックアップの盗難	**SQL インジェクション・権限のある内部者**
DB 暗号化（列）	特定の列だけ（アプリで復号）	DB 管理者からも隠せる	**アプリの脆弱性**

TDE はアプリを変えずに入れられるが、正規の SQL で読めば復号された値が返る。「暗号化したから SQL インジェクションでも安全」は誤り。

出典：IPA「支援士試験 シラバス（案）」用語例「ストレージ暗号化，ファイル暗号化，データベース暗号化」。表は Claude がまとめた

第2章

利用者認証の方式

要素の数、段階の数、状況に応じた強さ。

多要素と多段階、リスクベース

組合せ	要素	判定
パスワード＋秘密の質問	知識＋知識	多段階
指紋＋顔	生体＋生体	多段階
パスワード＋スマホのコード	知識＋所持	多要素
IC カード＋PIN	所持＋知識	多要素
パスキー（端末＋生体/PIN）	所持＋生体/知識	多要素

リスクベース認証



3D セキュア（R2 問9）：カード会社に**登録したパスワードなど本人しか分からない情報**で確認。EMV 3-D セキュアはリスクベースで、低リスクは追加入力なし。日本では 2025年3月末までに EC 加盟店で導入が求められた。

出典：NIST SP 800-63B／IPA 午前 II 令和2年度 問9／クレジット取引セキュリティ対策協議会「クレジットカード・セキュリティガイドライン 5.0 版」

ワンタイムパスワードとフィッシング耐性

方式	しくみ
TOTP	共有の秘密鍵＋**時刻**（30秒ごと、RFC 6238）
HOTP	共有の秘密鍵＋**カウンタ**（RFC 4226）
SMS コード	電話番号に送る。SIM スワップに弱い
チャレンジレスポンス	サーバの乱数に秘密で計算した応答。秘密は流れない

AiTM フィッシング（#02）で中継されるか

方式	フィッシング耐性
パスワード＋SMS/TOTP	ない（中継される）
プッシュ通知の承認	ない（MFA 疲労も）
FIDO2・パスキー	ある（ドメインに結び付く）
クライアント証明書の TLS 相互認証	ある

出典：RFC 4226・RFC 6238／IPA「支援士試験 シラバス（案）」用語例「フィッシング耐性のある認証」／NIST SP 800-63B

身元確認（Identity Proofing）と当人認証：SP 800-63

登録のとき
身元確認＝IAL
本人と身分証を照合

→

ログインのたび
当人認証＝AAL
認証器で確認

→

連携のとき
FAL
IdP からの主張の強さ

3つの保証レベルを**分けて**決める。2025年に第4版（SP 800-63-4）が公表された。

R7秋 問11 Identity Proofing はどれか

選択肢	正体
登録時に**本人と写真付き身分証を照合**	**身元確認（正解）**
登録時に希望の ID の重複を確認	**ID の管理**
ログイン後にメールで本人に通知	**ログイン通知**
ログイン時に ID とパスワードを照合	**当人認証**

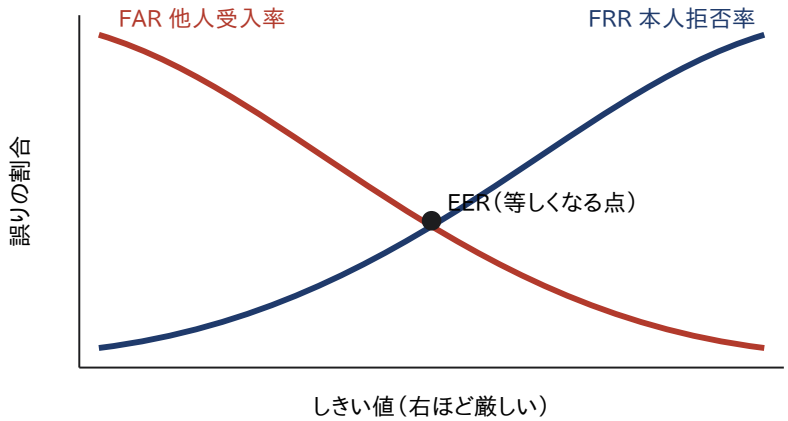
出典：NIST SP 800-63-3（Digital Identity Guidelines）・SP 800-63-4（2025）／IPA 午前 II 令和7年度秋期 問11

第3章

生体認証とパスワードレス認証

生体情報は端末から出さない。

生体認証の精度：FRR・FAR・EER



指標	意味
FRR	本人を拒否する割合（使いにくさ）
FAR	他人を受け入れる割合（危なさ）
EER	FRR＝FAR の点。小さいほど高精度

しきい値を厳しく → FAR↓ FRR↑。緩く → FAR↑ FRR↓。

R7秋 問10：成人の**虹彩**は変わらない → 更新ほぼ不要（正解）。静電容量方式の指紋は照明の影響なし。コイルの誘導起電力は**非接触型** IC カード。

出典：JIS X 8101（ISO/IEC 19795-1）／IPA 午前 II 令和7年度秋期 問10。グラフは Claude が模式的に描いた

ライブネス検知と、生体認証の弱点

種類	しくみ	例
アクティブ	利用者に**動作を求める**	まばたき、首振り、数字を読む
パッシブ	動作を求めず**画像などから判断**	質感・奥行き・血流・反射

写真・動画・マスク・偽の指、ディープフェイク（#05）への対策。

特徴の種類

身体的特徴	指紋・静脈・顔・虹彩・声
行動的特徴	署名の筆跡・筆圧、キーストローク、歩き方

生体情報は**変更できない**。だからサーバに送らず、端末の中で照合する方式（FIDO）が望ましい。

出典：IPA「支援士試験 シラバス（案）」用語例「身体的特徴，行動的特徴，ライブネス検知（アクティブ検知，パッシブ検知）」

FIDO2・パスキーの認証の流れ

① サイト（RP）
チャレンジ（乱数）を送る
→
② ブラウザ（WebAuthn）
今のドメインを確かめて渡す
→
③ 認証器（CTAP）
生体/PIN で本人確認 → 秘密鍵で署名
→
④ サイト
登録済みの公開鍵で署名を検証

R6秋 問7：生体情報を受信するか	答え
利用者 A の Web ブラウザ	しない
Web サーバ B	しない
IdP	しない

R1秋 問1 UAF：「スマホで顔認証 → スマホ内の**秘密鍵で署名** → 署名を送る」が正解。「指紋情報を認証サーバに送信」は誤り。

サーバには**公開鍵だけ**。サーバから漏れても悪用しにくい。鍵はドメインごとなので偽サイトでは使えない。

出典：W3C「Web Authentication Level 2」／FIDO Alliance「CTAP 2.1」「Passkeys」／IPA 午前 II 令和6年度秋期 問7・令和元年度秋期 問1

まとめ：本番での問われ方

モデルを当てる：所有者が決める＝DAC、ラベルで強制＝MAC、役割＝RBAC、属性と状況＝ABAC。

要素を数える：知識・所持・生体の**種類が違えば**多要素。同じ種類を重ねても多段階。

暗号化の限界：TDE は媒体の盗難に効くが、SQL インジェクションや内部者には効かない。

FIDO の核心：生体情報と秘密鍵は端末から出ない。送るのは署名。サーバは公開鍵で検証。

言葉の区別：Identity Proofing（登録時の身元確認）と Authentication（ログイン時の当人認証）。FRR（本人拒否）と FAR（他人受入）。

SSO・SAML・OIDC・OAuth・Kerberos は **#11** で。

出典：IPA 午前 II（このPDFの問題演習）／IPA「支援士試験 シラバス（案）Ver.0.1」